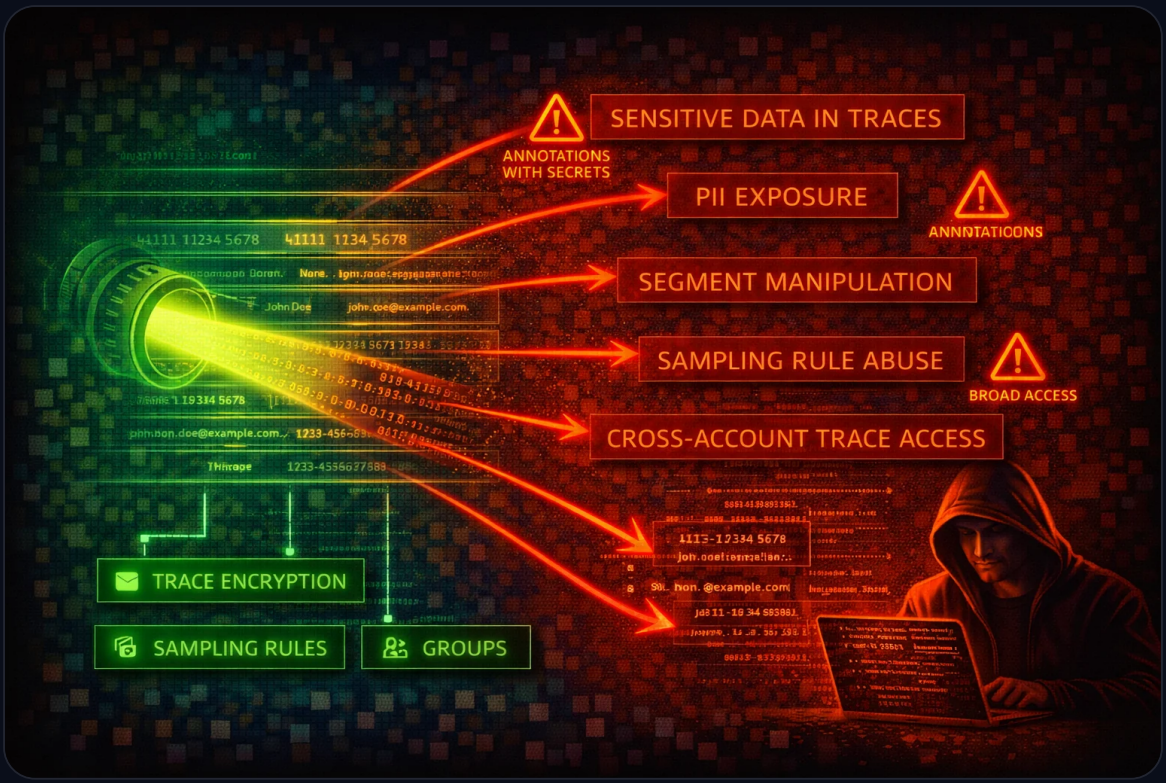


AWS X-Ray Security

MONITORING

AWS X-Ray is a distributed tracing service that collects data about application requests. Trace data can contain sensitive application details, PII in annotations/metadata, internal architecture topology, and downstream dependencies. X-Ray has been weaponized as a covert C2 channel (XRayC2).

HIGH	Always On	Opt-in	PROVEN
Data Sensitivity	Encryption at Rest	Data Events	C2 Abuse Risk

📋 Service Overview

Trace Data and Segments

X-Ray collects trace segments with timing data, annotations (indexed key-value pairs), and metadata. Annotations and metadata can inadvertently contain PII, secrets, database queries, or service topology.

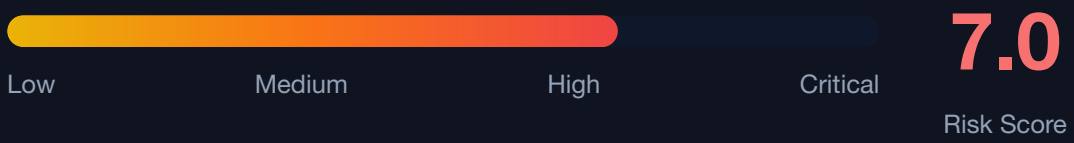
Attack note: Annotations are indexed and searchable via filter expressions -- any sensitive data in annotations is queryable by anyone with xray:GetTraceSummaries permission.

C2 Channel Abuse

X-Ray integrates with Lambda, API Gateway, ECS, EKS, EC2, SNS, SQS. The XRayC2 tool weaponizes X-Ray as a covert C2 channel by encoding commands into trace annotations.

Attack note: XRayC2 encodes commands into trace annotations via PutTraceSegments and retrieves results via GetTraceSummaries, blending malicious traffic with legitimate tracing data.

Security Risk Assessment



7.0

Risk Score

X-Ray trace data exposes application internals, service topology, and potentially PII. The service has been demonstrated as a viable C2 channel. Misconfigured encryption and overly broad IAM permissions amplify risk. However, X-Ray itself does not directly control infrastructure.

⚔️ Attack Vectors

Data Exfiltration via Traces

- Encode stolen data into trace annotations/ metadata
- Retrieve exfiltrated data via GetTraceSummaries
- Use base64-encoded payloads in annotation values
- Leverage cross-account observability (OAM links)
- Abuse put-resource-policy for cross-account trace access

Reconnaissance and C2

- Extract app topology from service graphs (GetServiceGraph)
- Map internal service dependencies from trace data
- XRayC2 three-phase C2: beacon, command, exfil
- Poll for commands using annotation filter expressions
- Enumerate sampling rules to understand traced traffic

⚠️ Misconfigurations

Encryption and Access

- Default AWS-managed encryption instead of CMK
- Granting xray:* to application roles
- CloudTrail data events not enabled for X-Ray
- PutTraceSegments from unexpected principals
- Missing resource policies for cross-account restriction

Data Exposure

- PII, secrets, or tokens logged in annotations
- Sensitive data in trace metadata (stored plaintext)
- Overly broad sampling rules capturing all traffic
- Not using X-Ray groups to isolate sensitive data
- AWSXrayCrossAccountSharingConfiguration unrestricted

🔍 Enumeration

List Encryption Configuration

```
aws xray get-encryption-config
```

List All Sampling Rules

```
aws xray get-sampling-rules
```

List All Groups

```
aws xray get-groups
```

Get Trace Summaries (Last 10 min)

```
aws xray get-trace-summaries \
  --start-time $(date -u -v-10M +%s) \
  --end-time $(date -u +%s)
```

List Resource Policies

```
aws xray list-resource-policies
```

📈 Privilege Escalation

Data Exfiltration Paths

- PutTraceSegments to encode arbitrary data
- GetTraceSummaries with annotation filters to retrieve data
- BatchGetTraces for full trace content
- GetServiceGraph for application topology mapping
- Cross-account OAM links for data movement

Key insight: PutTraceSegments is a data event in CloudTrail. Unless data events are explicitly enabled for X-Ray, these calls are invisible to audit logs.

🔗 Persistence

C2 Channel

- Beacon via PutTraceSegments with encoded commands
- Command delivery via trace annotations
- Exfiltration via trace segment metadata
- Polling via GetTraceSummaries with filter expressions
- Blends with legitimate tracing traffic

Data Access

- Maintain read access to trace data for recon
- Modify sampling rules to capture specific endpoints
- Create resource policies for cross-account access
- Modify encryption config to use attacker KMS key
- Create groups with filter expressions for target data

🛡️ Detection

CloudTrail Events

- PutEncryptionConfig - encryption changed
- CreateSamplingRule - sampling rule created
- PutResourcePolicy - cross-account policy changed
- CreateGroup - new trace group created
- UpdateSamplingRule - sampling modified

C2 Indicators

- Unexpected PutTraceSegments from non-app principals
- Repeated GetTraceSummaries with annotation filters
- Annotations containing base64 or unusually long values
- PutTraceSegments from IPs outside known infrastructure
- Unusual spikes in trace submission volume

💻 Exploitation Commands

Inject Data into Traces (Exfiltration)

```
aws xray put-trace-segments \
  --trace-segment-documents '{"trace_id":"1-67890abc-
def012345678abcdef012345","id":"abcd1234","start_time":1700000000
,"end_time":1700000001,"name":"exfil","annotations":
{"payload":"BASE64_ENCODED_DATA"}}'
```

Retrieve Exfiltrated Data

```
aws xray get-trace-summaries \
  --start-time $(date -u -v-1H +%s) --end-time $(date -u +%s) \
  --filter-expression 'annotation.payload BEGINSWITH "exfil"'
```

Get Full Trace Content

```
aws xray batch-get-traces \
  --trace-ids "1-67890abc-def012345678abcdef012345"
```

Get Service Graph (Topology)

```
aws xray get-service-graph \
  --start-time $(date -u -v-1H +%s) --end-time $(date -u +%s)
```

📜 Policy Examples

✗ Dangerous - Full X-Ray Access

```
{
  "Effect": "Allow",
  "Action": "xray:*",
  "Resource": "*"
}
```

Full control including encryption changes, sampling rules, resource policies, and ability to read/write all trace data

✓ Secure - Daemon Write-Only

```
{
  "Effect": "Allow",
  "Action": [
    "xray:PutTraceSegments",
    "xray:PutTelemetryRecords",
    "xray:GetSamplingRules",
    "xray:GetSamplingTargets"
  ],
  "Resource": "*"
}
```

Matches AWSXRayDaemonWriteAccess. Allows sending traces and sampling config only. No read access to trace data.

✓ Secure - Deny Encryption Downgrade

```
{
  "Effect": "Deny",
  "Action": "xray:PutEncryptionConfig",
  "Resource": "*"
}
```

Prevents non-admin roles from changing X-Ray encryption configuration

🛡️ Defense Recommendations

🔑 Enable Customer-Managed KMS Encryption

Use a CMK for full control over key rotation, auditing, and access.

```
aws xray put-encryption-config --type KMS --key-id
alias/xray-tracing-key
```

📝 Enable CloudTrail Data Events for X-Ray

Capture PutTraceSegments, GetTraceSummaries, and BatchGetTraces calls. These are not logged by default.

🚨 Monitor for C2 Indicators

Alert on unexpected PutTraceSegments, repeated GetTraceSummaries with annotation filters, and base64-encoded annotation values.

🔒 Restrict PutTraceSegments to Known Roles

Only application roles running the X-Ray daemon should have PutTraceSegments. Deny for human users.

⚙️ Review and Harden Sampling Rules

Audit sampling rules to exclude sensitive endpoints or sample them minimally.

```
aws xray get-sampling-rules
```

🧹 Sanitize Trace Data

Ensure application code does not log PII, secrets, API keys, or tokens in annotations or metadata.

AWS X-Ray Security Security Card

Always obtain proper authorization before testing